

Integração com API externa: Google OAuth 2.0

Este documento explica como o CyberEduca+ consome a API de autenticação do Google para permitir que o usuário entre na plataforma com a própria conta Google.

1. Qual API e por que usamos

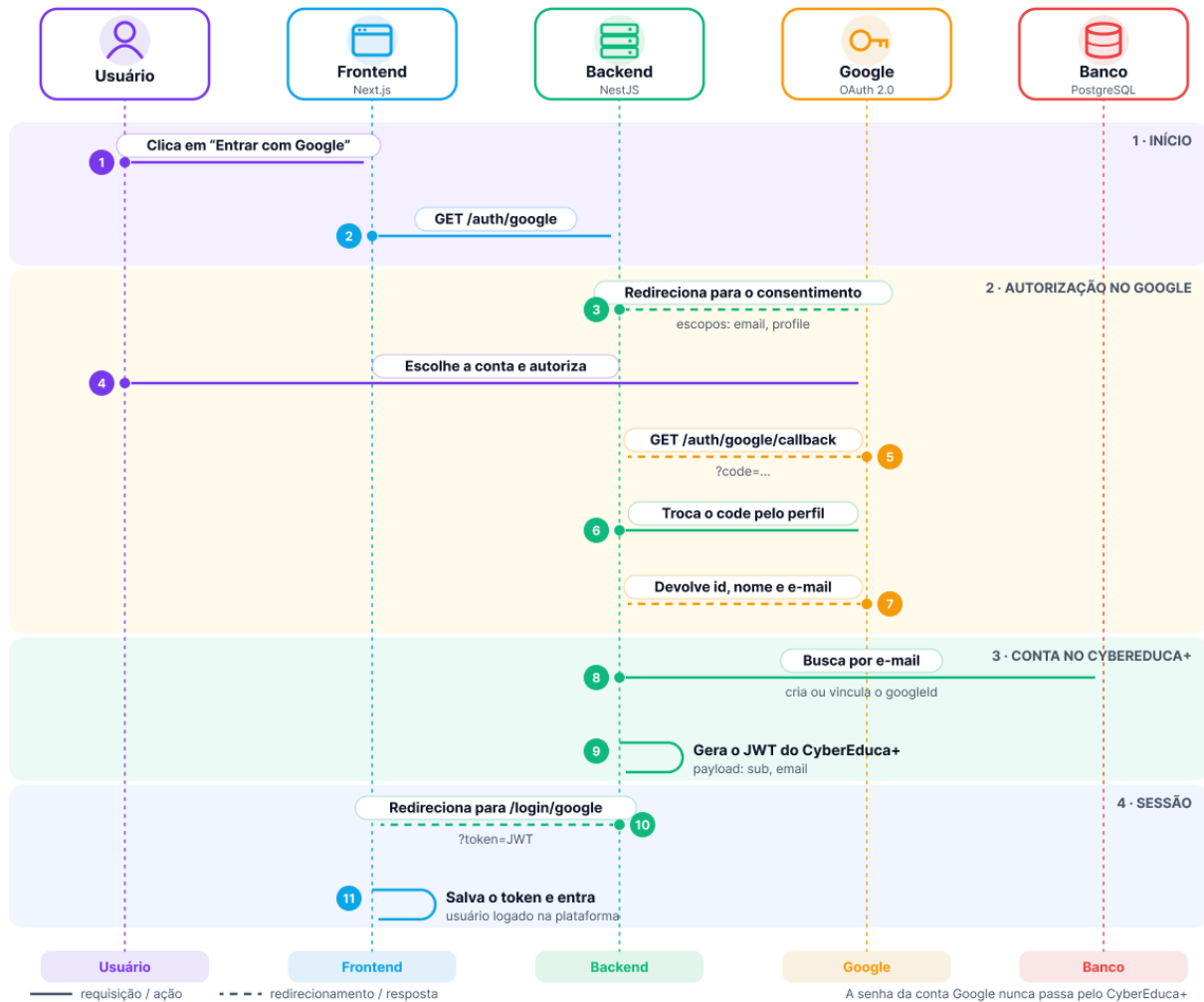
Item	Valor
Provedor	Google Identity (OAuth 2.0 + OpenID Connect)
Documentação oficial	https://developers.google.com/identity/protocols/oauth2/web-server
Biblioteca usada	passport-google-oauth20 (via @nestjs/passport)
Escopos pedidos	email, profile

O CyberEduca+ é uma plataforma com o objetivo de trazer conscientização de segurança da informação. Ao oferecermos login com Google, podemos reduzir o número de senhas que o usuário precisa criar e armazenar, o que é uma das boas práticas ensinadas nas próprias trilhas. Além disso, a plataforma não recebe e não armazena a senha da conta Google, quem valida a identidade é o próprio Google.

2. Fluxo da integração

Login com Google no CyberEduca+

Fluxo OAuth:



Após o fluxo completo de login e autenticação, o usuário que entrou pelo Google é tratado igual a quem entrou com e-mail e senha. Todas as rotas protegidas usam o mesmo JWT e o mesmo controle de acesso por papel.

3. Endpoints criados no backend

Método	Rota	O que faz
GET	/auth/google	Inicia o fluxo e redireciona o navegador para o Google
GET	/auth/google/callback	Recebe o retorno do Google, cria ou vincula o usuário e devolve o JWT ao frontend

Exemplo do retorno do Google

O Google devolve um perfil com vários campos. O sistema usa apenas três:

```
{  
  
  "id": "108234567890123456789",  
  
  "displayName": "Maria Silva",  
  
  "emails": [{ "value": "maria@gmail.com", "verified": true }]  
}
```

Exemplo do redirecionamento final

<https://cybereduca.vercel.app/login/google?token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...>

O conteúdo (payload) do JWT gerado é:

```
{ "sub": "id-do-usuario", "email": "maria@gmail.com" }
```

4. Onde está no código

Arquivo	Responsabilidade
backend/src/auth/google.strategy.ts	Configura o cliente OAuth e recebe o perfil do Google
backend/src/auth/auth.controller.ts	Rotas /auth/google e /auth/google/callback

Arquivo	Responsabilidade
backend/src/auth/auth.module.ts	Registra a GoogleStrategy como provider
backend/src/auth/auth.service.ts	Bloqueia login por senha em contas criadas só pelo Google
backend/prisma/schema.prisma	Campo googleId e senhaHash opcional na tabela Usuario
backend/prisma/migrations/20260927172035_add_google_auth/	Migration que cria o googleId
frontend/app/login/page.tsx	Botão "Entrar com Google", que leva para /auth/google
frontend/app/login/google/page.tsx	Recebe o token, salva e redireciona o usuário

Regra de criação e vínculo de conta

A função validate da GoogleStrategy cumpre com 3 regras principais:

1. **E-mail não existe no banco:** cria um usuário novo com nome, email e googleId, sem senha.
2. **E-mail já existe, sem googleId:** vincula o googleId à conta existente. O usuário tem a possibilidade de fazer login das duas formas.
3. **E-mail já existe, com googleId:** só faz o login.

Fora isso, se a conta Google não tiver e-mail, o login é recusado. Uma conta criada só pelo Google não tem senha, se alguém tentar entrar nela por e-mail e senha, o backend responde 401 Esta conta usa login com Google.

5. Configuração

5.1 No Google Cloud Console

1. Criar um projeto em <https://console.cloud.google.com>
2. Em **APIs e serviços** → **Tela de consentimento OAuth**, configurar o nome do app, o e-mail de suporte e os escopos email e profile.
3. Em **Credenciais** → **Criar credenciais** → **ID do cliente OAuth**, escolher **Aplicativo da Web**.
4. Em **URIs de redirecionamento autorizados**, cadastrar:
 - `http://localhost:3002/auth/google/callback` (desenvolvimento)

- `https://<url-do-backend>/auth/google/callback` (produção)
5. Copiar o **Client ID** e o **Client Secret**.

5.2 Variáveis de ambiente (backend/.env)

`GOOGLE_CLIENT_ID="xxxxxxx.apps.googleusercontent.com"`

`GOOGLE_CLIENT_SECRET="xxxxxxx"`

`GOOGLE_CALLBACK_URL="http://localhost:3002/auth/google/callback"`

`FRONTEND_URL="http://localhost:3001"`

As variáveis estão no `.gitignore`. Essas variáveis não vão para o frontend e nem para o repositório no github.

5.3 Banco de dados

`cd backend`

`npx prisma migrate deploy`

6. Erros e limites

Situação	Comportamento
Usuário cancela na tela do Google	Google retorna erro no callback; o usuário volta ao login
Conta Google sem e-mail	Login recusado
Client ID ou Secret inválidos	O Google recusa a troca do código; nenhuma conta é criada
URL de callback diferente da cadastrada	O Google bloqueia com <code>redirect_uri_mismatch</code>
Tentativa de login por senha em conta só Google	401 Esta conta usa login com Google.

7. Dados pessoais e LGPD

Dado recebido do Google	Onde fica	Para que serve
Nome	Usuario.nome	Exibir no perfil e no painel
E-mail	Usuario.email	Identificar a conta e evitar cadastro duplicado
ID Google	Usuario.googleId	Vincular a conta Google ao usuário

O projeto utiliza apenas o nome, email e google ID, esses dados são vinculados a uma conta no banco de dados, são criptografados e não são acessíveis a ninguém.